CUBE Collapses to a Point: A Zero-Query Identity-Proof Forgery Against CUBE

Martin Feussner
Selmer Center, University of Bergen
martin.feussner@uib.no

18 October 2026

This audit used the OpenAI model Daybreak Blue at the ultra reasoning level. OpenAI Codex generated and selected the paper title and deliberately chose "CUBE Collapses to a Point" as geometric/group-identity wordplay tied to the scheme name. OpenAI Codex performed AI-assisted target discovery and reconstruction, attack-history searching, cryptanalysis, implementation, experimentation, review coordination, and technical writing. A separately tasked AI agent performed hostile adversarial review and returned `PASS_ADVERSARIAL_REVIEW` after a provider-bound evidence correction. A fresh-context AI agent independently inspected the paper and pinned source, rebuilt and executed the frozen full-parameter implementation, checked every result field and control, and returned `PASS_INDEPENDENT_REPRODUCTION`. The final independent attack-history recheck returned `PASS_NO_PRIOR_TARGET_ATTACK`. Independent human verification was not performed; it is optional and nonblocking.

Abstract

CUBE, proposed in IACR ePrint 2026/920, combines partially blind BBS signatures with a Fiat–Shamir proof used by an on-chain credential verifier. Its ordinary verifier accepts a proof $\pi = (\bar{A}, \bar{B}, U, s, t, u_\gamma)$ when

$$e(\bar{A}, X) = e(\bar{B}, G_2), \qquad U + c\bar{B} = sC_J + t\bar{A} + u_\gamma H_\gamma.$$

Neither the paper nor the pinned verifier requires the three proof points to be nonidentity. Set $\bar{A} = \bar{B} = U = \mathcal{O}$ and $s = t = u_\gamma = 0$. Both equations then hold for every challenge, disclosed attribute vector, context, public key, and set of public bases. The resulting proof needs no signature, witness, secret, issuance interaction, hash collision, or malformed point.

In the paper's Sys-EUF-CMA game, the adversary makes zero signing-oracle queries and submits this proof for any explicit attribute vector. The query set is empty, so the vector is fresh and ordinary verification accepts. This is a full-parameter, probability-one fresh-message forgery in the stated game. An Arkworks harness using actual BN254 pairings and the pinned Solidity Keccak-256 transcript accepted the candidate in both the deployed five-word profile and a paper-complete profile containing five explicit attributes, a nullifier, and an address term. Execution took 0.03 seconds and 2,048 KiB peak resident memory. Honest proofs accepted, while four single-component mutations and an honest-message mutation rejected.

A canonical read-only Sepolia replay made twelve public JSON-RPC calls. The author-listed verifier accepted the zero proof on two input vectors, and a historical-state simulation of the ordinary issuer accepted mint calldata whose nine proof words alone were zeroed. Mutation and precommit-state controls rejected. No transaction was sent, no private key was used, and this evidence neither claims a broadcast forged mint nor an independent source-to-runtime-bytecode match. A fresh-context independent reproduction returned PASS. Generic BBS specifications had already required nonidentity proof points; we claim no novelty for that rule or for the identity-element technique.

1 Introduction and exact result

Lai introduces CUBE (Credential Unlinkability using Blinded Elements), a partially blind BBS credential framework intended to provide unlinkable on-chain identity proofs and Soulbound Token minting [1]. Its five algorithms are $\Pi = (\mathsf{Init}, \mathsf{Apply}, \mathsf{Sign}, \mathsf{Prove}, \mathsf{Verify})$. A user obtains a BBS signature over public

attributes and hidden address, nullifier, and blinding components, randomizes that signature, and presents a Fiat–Shamir proof. The on-chain verifier reconstructs the disclosed commitment, verifies two group relations, consumes a nullifier, and permits minting.

The proof verifier omits a standard boundary condition: every received proof point may be the group identity. At the identity, the two verification relations lose all dependence on the alleged signature and witness. Our exact claim is:

> The ordinary CUBE verification equations in ePrint 2026/920 admit a zero-signing-query Sys-EUF-CMA forgery at the full BN254 parameters. The all-identity, all-zero proof is accepted for an attacker-chosen explicit attribute vector that was never submitted to the signing oracle.

The weakness is design-level. It follows directly from the printed equations, uses valid group elements, and remains when the paper's address and nullifier terms are included in C_J. The pinned Solidity source implements the same two equations and explicitly represents the BN254 identity as $(0, 0)$. The attack does not use the source's separate omission of the address term, a fixture key, a parser discrepancy, invalid-curve input, nonce failure, or any accidental deployment condition.

"Zero-query" refers to the issuance/signing oracle in the paper's security game. An application may still require ordinary public workflow steps, such as registering an unused nullifier. Those steps do not provide a signature or credential witness. Our deployed evidence is deliberately narrower than an exploit claim: it consists only of read-only calls and historical-state simulations, not a broadcast mint.

Contributions. We give the exact CUBE equations and game; prove the universal identity-proof forgery; execute it with actual full-parameter BN254 pairings under both the source and paper-complete profiles; exercise the author-listed Sepolia addresses through a provider-bound, read-only simulation with state and mutation controls; report hostile review and fresh-context independent reproduction; place the result against generic BBS nonidentity-validation prior art; and state repair directions and evidence limits.

2 Target, version, and source identity

The target is the initial/current object of *CUBE: Partially Blind BBS Signatures for Unlinkable Decentralized Identity*, IACR ePrint 2026/920, received 10 May and approved 14 May 2026 [1]. The retained 20-page PDF has SHA-256 digest

`97795d68928f1537ed963b6ee2870c85ebc6efd4b41c13a73fffb1af246ecaff.`

The extracted text used for equation cross-checking has SHA-256 digest

`5b1879c6ac33c418963bfb3fe365a8c65ae460b4fb1cff8537a88e0f42b5d2b8.`

The paper-linked author repository is `LetsVerify/demo_v2`. We pin the clean source [2] at commit

`2af179dc02692c188c51125a3a6d98cf8f67faef`

and tree

`24e8f8377199792af57b5d65204e25df9ad44e3e.`

The relevant source files are:

File	SHA-256
src/BBSMath.sol	68e311ec9ccc7542f2f3aa5b975baad66b1e979a05088945671281ad1477e6d4
src/BBSVerifier.sol	bdadd310771f86238cdd913100a3f65bff701c58fe5893631f27abef3e5278c7
src/IssuerVerifier.sol	209d8ca493a5cb92e2993e6884015061e0e1ab0d6537dbbc68789a2e40093914
script/IssuerVerifier.s.sol	3b08bcc2fba95d23a94e0fe66c07fcfac1d64a43ff45880bb35058aeff9030ea

The selected source profile is `CUBE-BN254-M5-KECCAK256-SEPOLIA-2AF179D-V1`. It uses the BN254 scalar field of order

$$21888242871839275222246405745257275088548364400416034343698204186575808495617,$$

five disclosed 32-byte words (four configured constraints and m_{null}), one hidden m_γ, a Keccak-256 Fiat–Shamir challenge, and the ordinary Solidity verifier. The paper's smallest evaluated row has five explicit attributes. We therefore also test a paper-complete seven-disclosed-word profile containing those five attributes, m_{null}, and m_{Addr}, with m_γ hidden.

The author repository lists the Sepolia verifier

`0xCE5e36a94C099f84248aEA51fdfa8C36fFcFCFc8`

and issuer

`0x8D9d696193C04E4d9CfeBD01f522862A88202AC3.`

Those addresses identify the deployed behavior checked in Section 5.2; they do not establish source/runtime equivalence.

3 CUBE signatures, proofs, and security game

3.1 BBS commitment and randomized proof

The construction instantiates the short BBS signature and its proof-of- knowledge setting [4, 5]. Let $\mathbb{G}_1, \mathbb{G}_2, \mathbb{G}_T$ be cyclic groups of prime order p, written additively in the source groups, and let

$$e : \mathbb{G}_1 \times \mathbb{G}_2 \longrightarrow \mathbb{G}_T$$

be a nondegenerate bilinear pairing. Let $G_1 \in \mathbb{G}_1$ and $G_2 \in \mathbb{G}_2$ be generators. A signer selects $x \in \mathbb{Z}_p$ and publishes $X = xG_2$. For explicit messages $m_0, \ldots, m_{\ell-1}$, nullifier seed m_{null}, address scalar m_{Addr}, and hidden blinding scalar m_γ, define

$$C_J = G_1 + \sum_{i=0}^{\ell-1} m_i H_i + m_{\text{null}} H_{\text{null}} + m_{\text{Addr}} H_{\text{Addr}}, \tag{1}$$

$$C = C_J + m_\gamma H_\gamma. \tag{2}$$

The partially blind signing phase returns $\sigma = (A, e_s)$, where

$$A = (x + e_s)^{-1} C. \tag{3}$$

We write the signature scalar as e_s to distinguish it from the pairing.

To prove possession, the user selects randomizers r, α, β, δ and computes

$$\bar{A} = rA, \tag{4}$$

$$\bar{B} = rC - re_sA = rC - e_s\bar{A} = x\bar{A}, \tag{5}$$

$$U = \alpha C_J + \beta\bar{A} + \delta H_\gamma. \tag{6}$$

The Fiat–Shamir challenge and responses are

$$c = H(ctx \parallel \vec{m}_J \parallel \bar{A} \parallel \bar{B} \parallel U), \tag{7}$$

$$s = \alpha + rc, \qquad t = \beta - e_s c, \qquad u_\gamma = \delta + r m_\gamma c. \tag{8}$$

The proof is $\pi = (\bar{A}, \bar{B}, U, s, t, u_\gamma)$.

The pinned Solidity verifier serializes ctx, every disclosed scalar as a fixed-width 32-byte word, and the affine x, y coordinates of $\bar{A}, \bar{B}, U$ using `abi.encodePacked`. It reduces Keccak-256 modulo the BN254 scalar-field order. This byte-level detail does not help the attack: its equations hold for every resulting c.

3.2 Ordinary verification

After reconstructing C_J, the paper accepts exactly when

$$e(\bar{A}, X) = e(\bar{B}, G_2), \tag{9}$$

$$U + c\bar{B} = sC_J + t\bar{A} + u_\gamma H_\gamma. \tag{10}$$

The source implements Equation (9) as one two-pair BN254 precompile call and Equation (10) with the ordinary addition and scalar-multiplication precompiles. It exposes an `isInfinity` function that recognizes $(0, 0)$, and `negate` preserves that value, but `verifyProof` never rejects an identity input.

The source profile reconstructs C_J from the five disclosed words and omits the paper's address term. The paper-complete experiment restores that term. Because the attack multiplies all of C_J by $s = 0$, the distinction has no effect on acceptance and is not part of the attack mechanism.

3.3 Exact Sys-EUF-CMA endpoint

Definition 1 of the target paper gives the following system game. The challenger runs $\mathsf{Init}(1^\lambda)$ and gives the adversary X and the public parameters. The adversary may query an interactive blind issuance oracle $\mathcal{O}_{\mathrm{Sign}}$ with a commitment $C_2^{(i)}$ and an explicit attribute vector

$$\vec{m}_{\mathrm{exp}}^{(i)} = (m_0^{(i)}, \ldots, m_{\ell-1}^{(i)}).$$

Let Q be the set of explicit vectors successfully signed. The adversary outputs

$$(\pi^\star, \vec{m}_{\mathrm{exp}}^\star, m_{\mathrm{null}}^\star, m_{\mathrm{Addr}}^\star, M^\star)$$

and wins when

$$\mathsf{Verify}(pp, X, \pi^\star, M^\star, m_{\mathrm{null}}^\star, m_{\mathrm{Addr}}^\star) = 1 \quad \text{and} \quad \vec{m}_{\mathrm{exp}}^\star \notin Q. \tag{11}$$

Thus freshness is explicit-vector freshness. The paper claims security under q-SDH and simulation extractability of the proof system. The attack below violates the proof-system premise before either hardness assumption is relevant.

4 Zero-query identity-proof forgery

Let $\mathcal{O}$ denote the identity of $\mathbb{G}_1$, and 1_T the identity of $\mathbb{G}_T$. The attack is a single fixed proof:

$$\pi_0 = (\bar{A}, \bar{B}, U, s, t, u_\gamma) = (\mathcal{O}, \mathcal{O}, \mathcal{O}, 0, 0, 0). \tag{12}$$

Theorem 1. *For every CUBE public key, base set, disclosed attribute vector, address, nullifier, context, and Fiat–Shamir challenge, π_0 satisfies the ordinary verification equations. Consequently, an adversary wins the paper's Sys-EUF-CMA game with zero signing-oracle queries and probability one.*

Proof. Bilinearity gives $e(\mathcal{O}, Q) = 1_T$ for every $Q \in \mathbb{G}_2$. Therefore

$$e(\bar{A}, X) = e(\mathcal{O}, X) = 1_T = e(\mathcal{O}, G_2) = e(\bar{B}, G_2),$$

so Equation (9) holds. The verifier computes some challenge c from the supplied statement and zero points. Its value is immaterial:

$$U + c\bar{B} = \mathcal{O} + c\mathcal{O} = \mathcal{O},$$

while

$$sC_J + t\bar{A} + u_\gamma H_\gamma = 0C_J + 0\mathcal{O} + 0H_\gamma = \mathcal{O}.$$

Thus Equation (10) also holds.

The adversary makes no query to $\mathcal{O}_{\mathrm{Sign}}$, hence $Q = \varnothing$. It chooses any explicit attribute vector $\vec{m}_{\mathrm{exp}}^\star$ and outputs π_0 with any syntactically valid public payload. Ordinary verification returns one, and $\vec{m}_{\mathrm{exp}}^\star \notin \varnothing$. Both conditions in Equation (11) hold. No probabilistic event remains. □

The adversary's cryptographic work is constant: encode three identity points and three zero scalars. In the Solidity ABI the three affine points occupy six words and the responses occupy three more, so the complete proof body is nine zero words. The attack performs no pairing, scalar multiplication, search, hash inversion, or signing operation. The verifier still computes its normal challenge and full equations.

Fresh signing consequence. The explicit vector is the security game's signed message. With Q empty, every chosen vector is fresh. At the application layer, the attacker selects the issuer's advertised constraints and an unused nullifier/address payload. The public nullifier-precommit step in the reference wrapper is a state prerequisite, not issuance authorization and not a signature. The canonical simulation in Section 5.2 confirms that the ordinary mint path reaches and accepts the zero proof once that prerequisite exists. We make no claim that this audit broadcast such a transaction.

Why this is a design attack. The identity is a valid element of the prime-order group and is expressly handled by the source. The paper itself prints Equations (9) and (10) without a nonidentity condition. The proof remains valid with nonidentity public keys and bases and with every paper-level message term present. A faithful, otherwise competent implementation of the stated predicate therefore accepts it.

5 Full-parameter experimental evidence

5.1 Primary BN254 reproduction

EXP-0001 was designed and sealed before execution. It did not use the imported candidate reproducer or accept its verdict. The Rust harness uses Arkworks BN254 points and calls `Bn254::pairing` directly for both sides of Equation (9). It implements the pinned source's fixed-width big-endian scalar and affine-point encoding and Keccak-256 challenge order. The public bases and public key are nonidentity, and the honest controls use a nonzero secret key and an ordinary BBS signature.

Two complete profiles were executed:

- **source-five-word**: five disclosed words matching the deployed verifier, plus hidden m_γ;
- **paper-complete**: five explicit attributes, m_{null}, and m_{Addr}, plus hidden m_γ.

Every frozen condition passed:

Check	Expected	Observed
Honest proof, source profile	accept	accept
Honest proof, paper-complete profile	accept	accept
π_0, source profile	accept	accept
π_0, paper-complete profile	accept	accept
π_0, second message/base/key instance	accept	accept
π_0, changed context	accept	accept
Change only $\bar{A}$ to G_1	reject	reject
Change only $\bar{B}$ to G_1	reject	reject
Change only U to G_1	reject	reject
Change only s from zero to one	reject	reject
Change one message under an honest proof	reject	reject

The release execution took 0.03 seconds wall time and 2,048 KiB maximum resident memory on one worker. Its offline locked build took 1:58.40 and 399,080 KiB. It sent and received zero socket messages. The result records `actual_bn254_pairings=true`, `signing_queries=0`, and `result=PASS`.

The single-component mutations matter. They demonstrate that the harness is not an always-accepting model and separately exercise the pairing and linear checks. The changed honest message demonstrates transcript binding for an ordinary proof. The attack succeeds because all algebraic components collapse together, not because messages or the challenge are ignored.

5.2 Canonical read-only deployed simulation

EXP-0004 is the canonical deployed record. An initial hostile review rejected an earlier package because its frozen command named a pruned provider while the successful terminal run had used an archive provider. EXP-0004 corrected that provenance issue prospectively: its wrapper accepts only

```
CUBE_RPC_URL=https://sepolia.gateway.tenderly.co ./run.sh
```

and binds that endpoint, command, permitted methods, safety properties, and claim scope into the terminal artifact ledger.

The experiment generated ABI calls to `verifyProof` selector `0xb2466d7b`. It used two distinct five-word arrays and contexts, and the nine proof words were zero. The probe made exactly twelve calls, limited to `eth_chainId`, `eth_getCode`, `eth_getTransactionByHash`, and `eth_call`. All eleven frozen conditions passed:

Canonical deployed check	Result
Endpoint reports Sepolia; verifier runtime code is nonempty	pass
Zero proof under message/context vector 1	true
Zero proof under distinct message/context vector 2	true
Single $\bar{A}$, U, and s mutations	false, false, false
Historical ordinary mint calldata at block 10,728,275	succeeds
Same calldata with only nine proof words zeroed	succeeds
Zeroed calldata with only U changed to $(1, 2)$	reverts
Zeroed calldata at block 10,728,274, before precommit	reverts

The historical transaction was

`0x3af16d645236a3b0759a6f137d59b0ff4b8089be0078876603cbadd4ff8e9d75`

at block 10,728,276. Both successful issuer calls were simulations at the immediately preceding state, before that transaction changed it. The earlier state control demonstrates that the wrapper's nullifier prerequisite was actually enforced; the U mutation demonstrates that the cryptographic failure is specific.

The read-only probe took 1.29 seconds and 22,528 KiB peak resident memory; its one-worker vector build took 8.20 seconds and 181,060 KiB. It sent no transaction and used no private key. The runtime bytes returned at the author-listed verifier address had SHA-256

`74f897ffaffd37e7ec395393e2ed904c8249b8852191158ccfa04a93feece25b.`

That digest identifies the bytes observed; the audit did not independently compile the pinned source and match it to those bytes. The supported claim is exactly *read-only simulated behavior at the author-listed addresses.* It is not a broadcast forged mint and not a source-to-runtime-bytecode conformance result.

5.3 Evidence identities

The principal frozen identities are:

Object	SHA-256
EXP-0001 code manifest	`707188a3bf6683a75e45d8c4e0744e5bcb984442300a3f3fa6e05287dd02f78d`
EXP-0001 artifact manifest	`5682116238a57892beea1fe7ea88ae3cb89544dc44bba0cc42a7cff0463bebe8`
EXP-0001 normalized result	`e4d142dc85a9a05ec80bc28b6b47e93f438e99577ac25930084f1e71051cfe7e`
EXP-0004 code manifest	`4d7167287953125e6aaba923cfe6ca1860faa224f4b2c0972b043512b169b6b2`
EXP-0004 artifact manifest	`13fa47eef69a0d29ee0fba266eb2cd48dd3fb496ce28fd65d9078ada17bda7d4`
EXP-0004 normalized result	`ad64ed233f6d7a4b2373d0aec5395cb8079aabaff1498a2e09e215e868762b32`
EXP-0004 run ledger	`a0138b1629912a3c5ce4e39588578b79b3201dd22b87a29d2c286ec4ba6b5f03`

These runs establish full-parameter behavior rather than a reduced toy instance. They are deterministic conformance executions, not a statistical estimate. The algebraic proof supplies universality; the experiments show that the concrete BN254 and Solidity boundaries preserve it.

6 Independent reproduction and hostile review

The hostile reviewer independently assessed the equations, Sys-EUF-CMA freshness condition, valid identity representation, paper-complete address and nullifier terms, source boundary, controls, and practical cost. It returned `PASS_CRYPTOGRAPHIC_CLAIM` while initially withholding package approval for

the provider ambiguity described above. After the canonical EXP-0004 correction and record reconciliation, the reviewer returned `PASS_ADVERSARIAL_REVIEW`. It expressly limited the deployed claim to read-only simulations at the author-listed addresses.

EXP-0005 then assigned a fresh-context AI reproducer the prospective design, paper, pinned source, frozen implementation, exact command, and pass criteria. Before its verdict, the reproducer was prohibited from reading the imported candidate, primary artifacts, deployed artifacts, and primary or hostile review conclusions. It replayed the code and source-input manifests, rebuilt offline with one job, executed `./run.sh` once, replayed the terminal artifact manifest, and evaluated every field rather than trusting the emitted PASS label.

The independent run reproduced every acceptance and rejection in the primary table. It used actual Arkworks BN254 pairings, both source and paper-complete profiles, changed messages and context, honest accepting proofs, and the four candidate mutations. The locked build took 1:59.46 with 399,240 kB peak RSS; execution took 0.03 seconds with 2,048 kB peak RSS. Both phases reported zero socket messages and zero swaps.

Independent object	SHA-256
EXP-0005 code manifest	`20d66f1b0b25f29c1aee248aacd76b430f17b7228abdc48676f3d130db2eab1a`
EXP-0005 source-input manifest	`f5759a81b58dc0325a8fd692f9c426856923e5d683c7f89a9be6f0e58928e3db`
EXP-0005 artifact manifest	`b4cfe964edaf2f6390cb6518bc74b130feeafca37d050dc2711774f619848842`
EXP-0005 normalized result	`e4d142dc85a9a05ec80bc28b6b47e93f438e99577ac25930084f1e71051cfe7e`
Executed release binary	`836708bdd695962e9ad4e4438710cfb9b5f1d27782aea0d98ccf870e1b04f7e5`
Independent report	`64158dd1595d66eb914dae110b323c59f34ba149c74454cc56751f1c3fd8b2cf`

This is independent reproduction of the frozen implementation and conclusion, not a separately written verifier and not an independent deployed-bytecode match. The input boundary and independent field assessment supply the relevant separation from the primary run.

7 Security consequence and proof failure

The target paper's unforgeability theorem reduces a successful proof to a BBS signature forgery by invoking simulation extractability or proof of knowledge. Theorem 1 exhibits an accepting transcript that contains no BBS signature witness at all. Therefore the stated proof system does not satisfy the knowledge premise on the verifier's accepted domain. Rewinding the fixed identity commitments under another challenge yields another all-zero accepting transcript; subtracting responses reveals only zeros, not a witness satisfying the claimed relation.

The result does not challenge q-SDH or the unforgeability of a correctly validated BBS signature or proof system. It shows that CUBE's acceptance predicate is broader than the relation assumed by the reduction. The normal hardness assumptions never become active on the identity branch.

The immediate impact is an efficient credential-proof forgery for arbitrary explicit attributes under the paper's game. It does not recover the signer's secret key or an equivalent signing key. Nor does it evaluate privacy, blindness, unlinkability, or traceability after a valid issuance; the violated property is system unforgeability and its ordinary verification/minting endpoint.

8 Prior art and final attack-history result

The identity-element mechanism and its validation rule are not new. The 23 October 2022 CFRG BBS draft requires each of its three serialized proof points to decode to a valid G1 point different from the identity [6]. The current draft retains identity rejection [7], and a 2025 CFRG discussion expressly notes nonidentity validation for BBS proof points [8]. These are generic BBS specifications and discussion, not attacks on CUBE.

Accordingly, we make no novelty or priority claim for rejecting identity points, for the group-identity cancellation, or for the underlying attack technique. The target-specific contribution is the observation, proof, and full-parameter reproduction that CUBE omits the established validation and therefore accepts a zero-query forgery through its ordinary verifier.

The final post-reproduction history recheck searched the exact title, ePrint identifier, CUBE expansion, author, repository, author-listed addresses, identity/zero-proof terms, scholarly indexes, public development history, issues, pull requests, releases, citations, corrections, and disclosures. It returned

`PASS_NO_PRIOR_TARGET_ATTACK`.

No prior public attack against CUBE was located in the searches performed as of 18 October 2026. This is a dated and bounded negative result, not an absolute first-ever claim; it cannot exclude private, deleted, embargoed, unindexed, or later disclosures.

The recheck found the same work's IEEE proceedings record: *CUBE: Partially Blind BBS Signatures for Unlinkable Decentralized Identity—A Succinct On-Chain Verifiable Credential Framework*, 2026 6th International Conference on Computer Science and Blockchain, pages 37–44, DOI 10.1109/CCSB71176.2026.11716519 [3]. That record is a publication instance of the target work, not an attack, correction, or independent security analysis. No adverse exact-target history was located around it.

The final-history report has SHA-256

`1ba8f4a4f3f8dfc4b3e98b90eb50cd8c43e78b9e31ec9464a754f5fd8ce53a74,`

and its bundle manifest has SHA-256

`84a8360c1e63e17663331aa42d87b4929e03140f33cb55da9c8bb0c857912b4c`.

9 Repair directions

At minimum, verification must reject the group identity for every proof point whose protocol role requires a nonidentity value, before pairing or linear checks. In this construction that means validating $\bar{A}$, $\bar{B}$, and U as canonical, on-curve, correct-subgroup, nonidentity G1 elements. The prover should sample the signature randomizer from $\mathbb{Z}_p^*$ and abort or resample on any forbidden identity. The decoder and smart contract should apply the same normative rule. Checking whether the Fiat–Shamir challenge is zero does not help because Equation (12) works for every challenge.

These checks are necessary to remove the demonstrated branch, but this audit does not claim they constitute a complete proof repair. A revision should restate the exact NP relation and accepted domain, prove special soundness or simulation extractability for that domain, and test the implementation against all-identity proofs and single-component mutations. The unforgeability reduction must extract a genuine BBS witness from every accepted proof rather than assume that fact.

The source and paper should also be reconciled so that the address term $m_{\mathrm{Addr}}H_{\mathrm{Addr}}$ is bound consistently. That separate issue is not needed for this attack and adding the term alone does not block it. Any repair should be tested in both the complete paper profile and the deployed wrapper, including nullifier state transitions and negative controls. We have not implemented or validated a patched CUBE design.

10 Limitations

The evidence and claim are bounded as follows:

- the attack targets the initial/current ePrint 2026/920 object and the pinned author source commit named above;
- the fresh-message consequence is the explicit-attribute-vector freshness defined by the paper's Sys-EUF-CMA game;
- EXP-0001 and EXP-0005 use synthetic valid BN254 keys, bases, and scalars in an exact-equation conformance harness; they do not execute an EVM or deployed bytecode;
- EXP-0004 establishes read-only simulated behavior at author-listed Sepolia addresses; it sent no transaction, used no private key, and does not claim a broadcast forged mint;
- no independent compilation established a source-to-runtime-bytecode match for those addresses;
- the source's missing address term is a separate conformance issue and is not used as the attack mechanism;

- the deterministic executions establish concrete full-parameter instances rather than a random-trial success frequency; universality follows from the algebraic proof;
- the audit claims fresh-message proof forgery, not secret-key or equivalent-key recovery;
- the history conclusion is limited to public material accessible and indexed by the search cutoff; and
- independent human verification was not performed and is optional, nonblocking provenance.

11 Conclusion

CUBE's verifier accepts three proof points without excluding the group identity. At that point, both the pairing relation and the Fiat–Shamir linear relation become identity equalities, regardless of the challenge, public key, messages, context, or bases. A fixed nine-word zero proof therefore wins the paper's Sys-EUF-CMA game with no signing query and no witness.

Actual BN254 pairings, the paper-complete address-bound profile, the pinned Solidity transcript, discriminating controls, a canonical read-only deployed simulation, hostile review, and fresh-context independent reproduction all confirm the same result. The repair principle is established generic BBS prior art, and no technique novelty is claimed. The CUBE-specific conclusion is nevertheless direct: its ordinary full-parameter verifier admits an efficient fresh-message credential forgery.

Acknowledgements

The computations were performed on the Norwegian Research and Education Cloud (NREC), using resources provided by the University of Bergen and the University of Oslo.

References

[1] G. Lai, "CUBE: Partially Blind BBS Signatures for Unlinkable Decentralized Identity," IACR Cryptology ePrint Archive, Report 2026/920, 2026. https://eprint.iacr.org/2026/920.

[2] G. Lai, "CUBE demonstration and reference contracts," GitHub repository at commit 2af179d, 6 May 2026.

[3] G. Lai, "CUBE: Partially Blind BBS Signatures for Unlinkable Decentralized Identity—A Succinct On-Chain Verifiable Credential Framework," in *2026 6th International Conference on Computer Science and Blockchain (CCSB)*, pp. 37–44, 2026. https://doi.org/10.1109/CCSB71176.2026.11716519.

[4] D. Boneh, X. Boyen, and H. Shacham, "Short Group Signatures," in *Advances in Cryptology—CRYPTO 2004*, LNCS 3152, pp. 41–55, 2004. https://doi.org/10.1007/978-3-540-28628-8_3.

[5] S. Tessaro and C. Zhu, "Revisiting BBS Signatures," IACR Cryptology ePrint Archive, Report 2023/275, 2023. https://eprint.iacr.org/2023/275.

[6] IETF CFRG, "The BBS Signature Scheme," Internet-Draft draft-irtf-cfrg-bbs-signatures-01, 23 October 2022. https://www.ietf.org/archive/id/draft-irtf-cfrg-bbs-signatures-01.html.

[7] IETF CFRG, "The BBS Signature Scheme," Internet-Draft draft-irtf-cfrg-bbs-signatures-13, 13 October 2026. https://datatracker.ietf.org/doc/draft-irtf-cfrg-bbs-signatures/.

[8] IETF CFRG mailing list, "Re: [CFRG] BBS point deserialization and validation," 16 December 2025. https://mailarchive.ietf.org/arch/msg/cfrg/gorMiOCYlpyPSDGOEOP-gZkwf3U/.